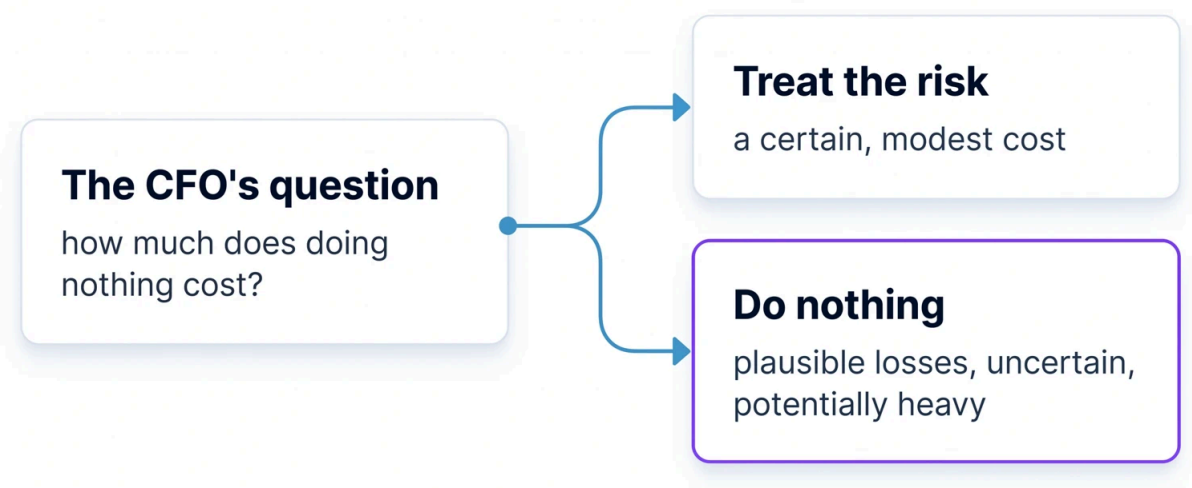


The CISO's briefing: Pricing the cost of inaction

✓ The budget question that decides everything else



Session objectives

By the end of this sequence:

- **Explain** what the cost of inaction is and why it is the central argument of a security investment request
- **Break down** the financial impact of a risk into its documentable components: business interruption, remediation, penalties, damage to trust
- **Draw on** real incident costs, sourced and dated, without making them say more than they do

- **Build** an honest investment justification for the Executive Committee, grounded in the risk register of the subsidiary under review

Prerequisites

- The EBIOS RM study of the subsidiary under review in CISO Assistant: the three risk origin / target objective pairs retained in session 5, on the subsidiary under review and its inter-subsidiary dependency from S6 of the subsidiary pack, the strategic scenarios added in session 6 and the first operational scenario, already rated for likelihood; the next ones will be rated this afternoon.
- The strategic scenarios and the first operational scenario built in session 6, with the critical stakeholders of the ecosystem.
- The risk appetite formulated in session 5: the acceptance line that executive management was asked to confirm.
- The governance from session 1: the Executive Committee, the COMEX in the everyday vocabulary of French companies, sets budget priorities, and this morning's work is addressed to it.

What to know before the exercise

Three notions are enough this morning, and they prepare the day directly: this afternoon, the register will be rated and the treatment plan costed in effort; someone, on the other side, will have to pay. That someone decides better when shown what refusal costs.

First, the problem. Since session 6, the group knows what it fears and which paths an attack would take. But an executive body does not arbitrate between scenarios, it arbitrates between expenditures: the security measure proposed this afternoon will be compared, explicitly or not, with what doing nothing costs. **The cost of inaction**, put simply, is the second branch of that alternative: the full set of plausible losses the organization would bear if an identified risk materialized without anything having been invested to reduce it. Its mechanics: it is not invented, it is documented, drawing on the costs of comparable incidents published by reliable sources, and it is tied to a specific scenario in the register, never to fear in general. Its limit, to know before arguing: it is an estimate of plausibility, not a prediction; nobody knows what the group's incident will cost, and a CISO who promises an exact figure loses credibility at the first counter-question.

The financial impact of a risk, in turn, can be broken down, and it is this breakdown that keeps the costing honest. Four components recur across documented incidents. Business interruption: the shipping group A.P. Moller-Maersk put the impact at 250-300 million dollars on its Transport & Logistics activities in the third quarter of 2017, in its financial communications, after the destructive NotPetya malware; the metals group Norsk Hydro puts the total cost of the March 2019 cyberattack at around 800 million Norwegian kroner on its website, after successive quarterly estimates. Remediation: rebuilding, investigating, notifying; these costs can be read in the same financial communications. Penalties and settlements: Equifax, whose 2017 breach had affected some 147 million people, reached a settlement of at least 575 million dollars in 2019 with the US regulator and fifty states; in France, the CNIL fined France Travail 5 million euros in January 2026 for failing to ensure the security of jobseekers' data, after

the 2024 leak that could affect 43 million people. And trust: the hardest to quantify, the longest to repair, the one that financial communications never fully detail.

The financial impact of a risk



Alongside individual cases, there are reference averages. IBM's Cost of a Data Breach report measures the average cost of a data breach every year: in France, 3.95 million euros in 2022, 3.75 million euros in 2023, then 3.85 million euros in 2024; worldwide, 4.44 million dollars in the 2025 report, down for the first time in five years. The same 2025 report puts the average breach lifecycle, identification and containment included, at 241 days. These averages have a precise use: giving an order of magnitude when no comparable case fits the scenario under study. And an equally precise limit: an average flattens the dispersion. The group will never suffer "the average cost"; it will suffer its own incident, which may cost ten times less or ten times more.

**€3.85
million**

AVERAGE COST OF A DATA
BREACH IN FRANCE IN 2024

IBM, Cost of a Data Breach Report 2024

\$4.44M

GLOBAL AVERAGE COST OF A
DATA BREACH, FIRST
DECREASE IN FIVE YEARS

IBM, Cost of a Data Breach Report 2025

241 days

GLOBAL AVERAGE BREACH
LIFECYCLE, IDENTIFICATION
AND CONTAINMENT INCLUDED

IBM, Cost of a Data Breach Report 2025

Investment justification, finally, is the art of assembling all of this into an argument the Executive Committee can decide on. Its canonical form has three parts: the scenario from the register (what is feared, with its place in the analysis), the plausible cost of inaction (documented, dated, sourced, as a range), and the cost of the proposed treatment: the measure, its effort, its deadline, and its annual cost, distinguishing what is invested once, the build, a capital expenditure (CAPEX), from what is paid every year, the run, an operational expenditure (OPEX); that cost

is worked out this afternoon, in the tool. The decision then becomes a trade-off between two numbers of different natures, a certain and modest cost against an uncertain and potentially heavy loss, and that is exactly the kind of trade-off an executive body knows how to make, because it makes it on all its other risks. What the justification does not do: it does not calculate a precise return on investment, because security produces avoided incidents, which cannot be measured. An argument that promises "this measure will earn this much" is an accounting fiction; an argument that says "here is what comparable organizations have lost, here is what the measure costs, here is our appetite" is a decision aid.

The cost-of-inaction range, in four terms. Loss per day of stoppage, multiplied by a duration, plus remediation, plus the penalty if any. The loss per day comes from the subsidiary pack: contractual penalties, blocked revenue, credit notes owed. The duration is taken twice: low, the outage the subsidiary has already lived through; high, what the documented cases show, days to weeks of manual mode. Remediation, rebuilding, investigating, notifying, is taken from the pack if the vendor or the hosting provider has priced it; otherwise the IBM average serves as an order of magnitude, stated as such. The penalty is added only if personal data is at stake, at the order of magnitude of France Travail. What the pack lacks is requested from the CFO, by name: an honest range says what it does not know.



💡 Method reflex: every figure brought before an executive body must answer three questions in one sentence: who does it come from, what year does it date from, and what in our register does it relate to. A figure that fails any of the three does not enter the file. It is the same sourcing discipline as for the deliverables, applied to the spoken word.

Case study: three arguments for the Executive Committee

Scenario and problem statement

Monday morning. The follow-up assessment sent at the end of session 6 showed the Executive Committee the state of the MERIDIAN file, and the reaction was immediate: the Chief Financial Officer asked, on the sidelines of the meeting, "how much is all this going to cost us, and above all, how much does doing nothing cost?". The question is an opportunity: it is the one that opens budgets, provided it is answered with facts.

The Group CISO (RSSI Groupe) is the point of view of this case. Their EBIOS RM study holds the three risk origin / target objective pairs retained in session 5 for the subsidiary under review and its inter-subsidiary dependency from \$6 of the subsidiary pack, and the scenarios derived from them since session 6. The strategic scenarios of session 6 showed which path the one targeting the availability of the subsidiary's critical asset would take: through the third parties that intervene remotely on that asset (\$3 and \$6 of the subsidiary pack). This afternoon, these risks will be rated and the treatment plan built. This morning is for preparing the financial arguments that will get it funded.

Guided questions

1. **Link** the cost references to the scenarios of the register of the subsidiary under review: one table, one row per scenario (unavailability of the critical asset, theft or leak of personal data, insider malice or error), with the documented reference from the briefing that best illuminates it, the nature of the cost it illustrates, the amount, the year, the source, and one sentence saying why it illuminates that scenario. When no reference fits, write it in the row: that is an answer.
2. **Draft** the investment argument for the unavailability scenario of the critical asset of the subsidiary under review. It opens with the reply to the Chief Financial Officer, a single sentence that lays out the alternative without dramatizing or minimizing. It continues in three parts: the scenario and its path; the plausible cost of inaction, as a low and a high range, calculated with the four terms of the framing, loss per day of stoppage taken from the subsidiary pack, low and high duration, remediation, penalty if any, and bounded by the briefing's references; when the pack does not quantify a term, name the data item to request from the CFO; the nature of the treatment to be proposed this afternoon, already saying what will be invested once and what will be paid every year, without costing it yet.
3. **Answer** the CFO's cross-examination: phrase the three objections the CFO will raise against the argument, as the CFO would say them, and for each the Group CISO's reply in one sentence, backed by a piece of the subsidiary pack or by the group's severity scale, never by a promise.

Working method

Allow 15 minutes for question 1, 20 minutes for question 2, 10 minutes for question 3. Rule out any figure that does not come from the briefing or the subsidiary pack: the exercise assesses sourcing discipline as much as argumentation. And keep the nature of the audience in mind: a CFO respects an honest range, distrusts suspicious precision, and respects even more a CISO who has anticipated the objections.



Answer keys and assessment criteria – cliquer pour révéler

+200 XP

Formation terminée !